

An Agentic Software Framework for Data Governance under DPDP

Apurva Kulkarni

International Institute of Information Technology
Bangalore
Bangalore, Karnataka, India
apurva.kulkarni@iiitb.ac.in

Chandrashekar Ramanathan

International Institute of Information Technology
Bangalore
Bangalore, Karnataka, India
rc@iiitb.ac.in

Abstract

Despite the rise of data-driven software systems in the modern digital landscape, data governance under a legal framework remains a critical challenge. In India, the Digital Personal Data Protection (DPDP) Act mandates rigorous data privacy and compliance requirements, necessitating software frameworks that are both ethical and regulation-aware. From a software development perspective, traditional compliance tools often rely on hard-coded rules and static configurations, making them inflexible to dynamic policy updates or evolving legal contexts. Additionally, their monolithic architectures obscure decision-making processes, creating black-box behavior in critical governance workflows. Developing responsible AI software demands transparency, traceability, and adaptive enforcement mechanisms that make ethical decisions explainable. To address this challenge, a novel agentic framework is introduced to embed compliance logic directly into software agents that govern and adapt data policies. In this paper, the implementation focuses on the DPDP Act. The framework integrates *KYU Agent* and *Compliance Agent* for this purpose. *KYU (Know-Your-User) Agent* supports semantic understanding, user trustworthiness modelling and *Compliance Agent* uses data sensitivity reasoning within a goal-driven, agentic pipeline. The proposed framework, built using an open-sourced agentic framework and has been evaluated across ten diverse domains, including healthcare, education, and e-commerce. Its effectiveness under DPDP, measured via an *Anonymization Score*, demonstrates scalable, compliant data governance through masking, pseudonymization, and generalization strategies tailored to domain-specific needs. The proposed framework delivers scalable, transparent, and compliant data governance through collaborative agents, dynamic policy enforcement, and domain-aware anonymization.

Keywords

Agentic Framework, Ethics, DPDP, Data Governance, Data Compliance, Software Engineering for AI, Data Privacy

1 Introduction

With the rapid proliferation of data-centric systems, organizational data workflows are becoming increasingly complex and heterogeneous. As reliance on data-driven decision-making grows, so does the risk of data breaches, leaks, and fraudulent activities. In response, governments worldwide have introduced stringent data protection regulations, mandating organizations to adopt accountable and transparent data governance practices [4]. In the Indian context, the Digital Personal Data Protection (DPDP) Act, 2023 establishes legal requirements for the collection, storage, processing,

and transfer of personal digital data. This regulatory shift underscores the urgent need for robust, explainable, and adaptable data governance frameworks. However, existing solutions often treat governance as a secondary concern, relying primarily on static, rule-based access control mechanisms. Such approaches are insufficient to handle the nuanced legal obligations and evolving contextual demands of modern data ecosystems.

DPDP and Data Governance

The Digital Personal Data Protection (DPDP) Act¹ is India's law for protecting individuals' data and granting individuals the authority to ensure their personal data is collected, stored, and used responsibly. It grants individuals rights over their personal data, including the ability to know how it is used, request corrections or deletion, and be notified of any breaches, while establishing clear obligations for organizations and government entities handling such data.

With the rapid growth of data-centric systems, designing solutions that comply with DPDP regulations is critical. From a software engineering perspective, adapting to the DPDP framework requires embedding privacy controls at every stage of the software development lifecycle. Across each phase of the data lifecycle, including collection, storage, sharing, and archival, it is essential to reference DPDP provisions and integrate appropriate technological safeguards. This includes implementing data lineage tracking and comprehensive audit logs to demonstrate compliance, deploying consent management systems to ensure usage aligns with approved purposes, and conducting regular privacy impact assessments. Effective DPDP governance ensures that data is managed with accountability, transparency, and built-in privacy, safeguarding both individual rights and organizational compliance.

2 Related Work

In today's data-centric world, privacy is often considered the most important compared to all the other principles of ethical software development. For example, healthcare software that collects sensitive medical data must ensure privacy protections to prevent unauthorized access or misuse. Protecting users' personal information is foundational to building trust and ensuring compliance. However, many frameworks [15], such as *Model-View-Controller (MVC) architecture* do not have any provision to incorporate privacy into the software design. Similarly, the traditional *Software Development Life Cycle (SDLC)* addresses only non-functional requirements such as scalability, performance, and availability but without any provision for privacy considerations. In such cases, the

¹<https://www.meitv.gov.in/static/uploads/2024/06/2bf1f0e9f04e6fb4f8fef35e82c42aa5.pdf>

software often treats privacy as an add-on or afterthought, typically introducing it in later stages like compliance audits. Any corrections required as a result of non-compliance are either impossible to incorporate or very costly to comply with.

Conventional approaches to embedding ethical considerations, such as Privacy by Design [5], which integrates privacy measures into the system design from the inception, often conflict with foundational software engineering principles like high cohesion and low coupling. While design paradigms such as Human-Centered Design (HCD) [10, 13], User-Centered Design (UCD) [14], and Value-Sensitive Design (VSD) [3, 9, 17] integrate user values, including privacy and accountability, their application remains mostly abstract and suited for greenfield development. Standards like ISO/IEC 27001, Microsoft’s Security Development Lifecycle (SDL) ², and the National Institute of Standards and Technology (NIST)’s Cybersecurity Framework (CSF) ³ provide operational guidance, yet lack integration into software architecture as first-class design constructs.

Furthermore, widely adopted software design models (e.g., Model-View-Controller) and SDLC practices address functional and non-functional requirements but overlook privacy as a systemic, adaptive concern. In practice, this results in privacy being bolted on post-development via tools such as Privacy Impact Assessments (PIAs) [18], Data Loss Prevention (DLP) systems [2], and access control frameworks [16], which often respond reactively rather than proactively. Although tools like Open Web Application Security Project (OWASP) ³, Zed Attack Proxy (ZAP) [12], SonarQube [11], and Bandit target security and vulnerability detection, domain-specific privacy solutions like Google Privacy Sandbox [8] and ARX [1] aim at compliance; they remain fragmented and lack a unified, explainable framework.

3 Motivation

Under the Digital Personal Data Protection (DPDP) Act, 2023, which mandates dynamic and purpose-bound data governance, there is a pressing need for *context-aware, agentic frameworks that operationalize legal semantics directly into software behavior*. This work responds to the gap by proposing a modular, domain-agnostic architecture that supports real-time, autonomous governance integrated seamlessly within existing and new data systems. This work presents a novel agent-oriented software framework that brings automation, compliance, and ethical reasoning into the core of AI-enabled software applications. The primary research contributions are:

Agent-based Compliance Automation: Introduces a pluggable, agent-driven framework that operationalizes DPDP compliance as a runtime, context-sensitive decision-making process, enabling dynamic adaptation to user trust levels and data sensitivity.

Modular Privacy-Preserving Infrastructure: Develops a software engineering layer for privacy enforcement that is both modular and interoperable, supporting integration with existing and heterogeneous systems via scalable anonymization strategies.

Quantifiable Cross-Domain Compliance: Establishes the use of

an interpretable, domain-aware *Anonymization Score* as a quantitative software metric for evaluating privacy-preserving effectiveness, enhancing auditability and traceability across sectors.

This framework reframes legal compliance not as a static policy overlay but as a programmable, auditable component of software architecture.

4 Agentic Software Framework for Compliance

This paper proposes a modular, multi-agent software framework for privacy-aware data access and processing, engineered to align with the DPDP Act. The framework described in Figure 1, adopts a layered, agentic paradigm where distinct functional responsibilities are distributed across perception, reasoning, orchestration, and execution layers. Each layer is designed to operate autonomously while interacting cohesively to ensure that data access decisions are both context-sensitive and legally compliant.

4.1 Perception Layer

At the foundational level, the environment layer provides contextual grounding for all agent operations. It incorporates a structured, SQL-based data store that ingests and persists heterogeneous datasets from CSV inputs. Metadata extractor captures the information regarding the data (data type, owner, and domain) and forms a *Metadata Repository*.

Compliance Pipeline: Legal DPDP Act document is written in plain language intended for human understanding, yet its complexity and unstructured nature make it unsuitable for direct machine interpretation. To enable user-specific data handling techniques, sensitivity analysis, and automated compliance reasoning, these laws must be transformed into a structured, machine-interpretable format. The proposed approach develops a *compliance pipeline*, which converts a legal document into a collection of machine-interpretable tuples.

The pipeline begins with Text Extraction, where the DPDP Act’s unformatted legal text is converted into raw, continuous text while preserving context. Next, Section Segmentation divides the text into semantically meaningful units such as consent, user rights, data fiduciary obligations, and cross-border data transfer, enabling focused analysis of specific rules. The segmented text is then processed through Named Entity Recognition (NER) to identify key entities including type of the data (personal, sensitive, anonymized), user roles (Data Principal, Data Fiduciary, Consent Manager), jurisdictions (India, foreign territories), and actions (collection, processing, sharing, erasure). Following this, Rule Extraction transforms complex legal language into logically structured, machine-readable rules. These rules are then organized through Tuple Construction into a standard format (Data Principal, Domain, Rules, Receiving Entity), where the ‘Data Principal’ represents the individual whose data is processed, the ‘Domain’ specifies the relevant sector, the ‘Rules’ encapsulate compliance conditions, and the ‘Receiving Entity’ denotes the party to whom data is disclosed.

All tuples are compiled into a structured knowledge base, referred to as a Compliance Repository that is used by the compliance agent to determine data sensitivity. The current *Compliance Repository* implementation contains 20 derived tuples over the DPDP Act. Table 1 illustrating a selected subset of these entries.

²<https://www.microsoft.com/en-us/securityengineering/sdl/practices>

³<https://owasp.org/>

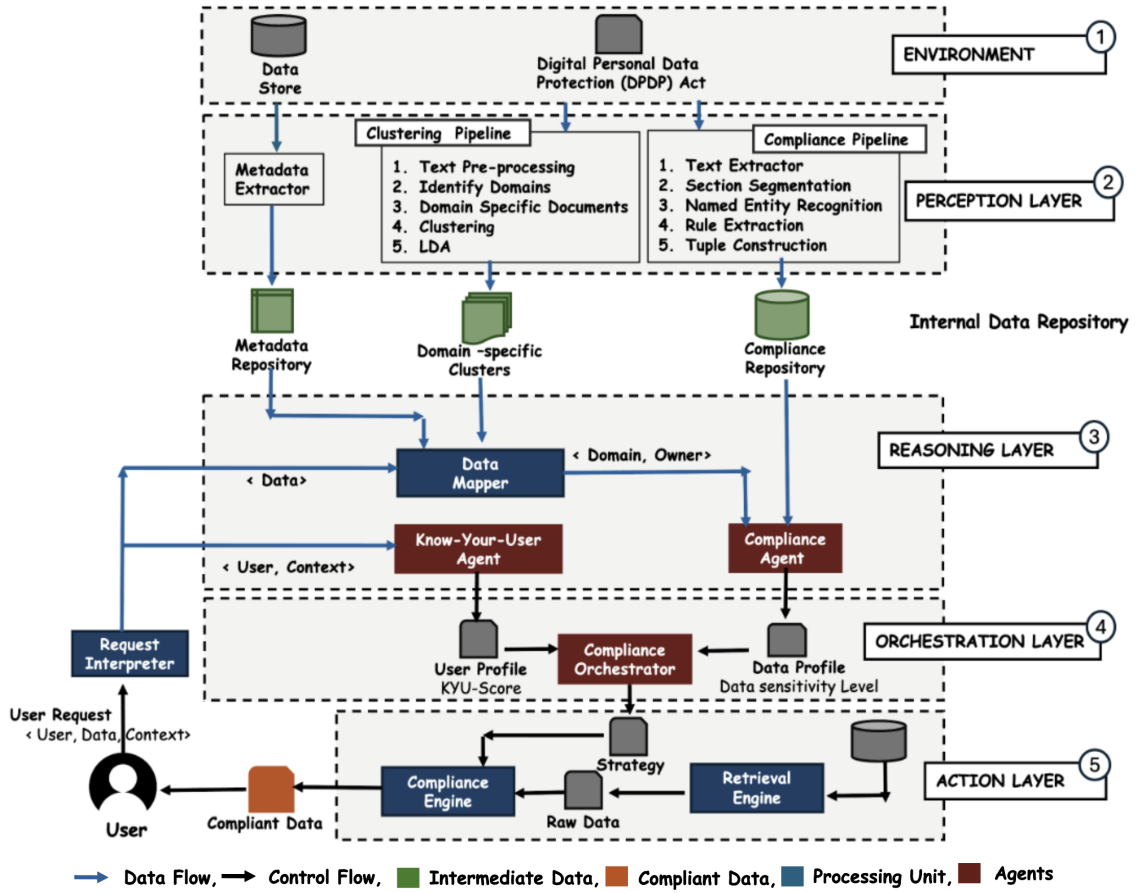


Figure 1: An Agentic Software Framework for Data Governance under DPDP

Clustering Pipeline: The *Clustering Pipeline* adds contextual awareness to the compliance system by determining the domain of each document, ensuring that compliance checks are targeted, relevant, and efficient.

It begins with Text Pre-processing, where the corpus (50-60 domain-specific documents) is cleaned using techniques such as tokenization and stop-word removal to prepare it for accurate clustering and downstream NLP tasks. In the Domain Identification stage, the content of processed documents is analysed to determine the appropriate domain (e.g., healthcare, finance, education), which is essential because compliance requirements differ across domains. The Clustering stage then groups related documents using K-Means clustering, where k equals the number of domains; in our case, 10 distinct domain-specific clusters have been identified⁴, improving data profiling, retrieval, and compliance matching. To further refine these clusters, Latent Dirichlet Allocation (LDA) is applied to uncover hidden topics within each domain's documents, enabling organization based on underlying semantic themes rather than surface-level keywords. This is particularly valuable in regulatory contexts where different terms may describe the same concept.

⁴The value of k is motivated by the distinct domains mentioned in the DPDP Act

The output of the *Clustering Pipeline* is the set of Domain-Specific Clusters, which is further leveraged by *Data Mapper* in the *Reasoning Layer*.

The *Perception Layer* supports both data-centric and policy-centric reasoning and is extensible to accommodate other regulations such as the GDPR (General Data Protection Regulation) or HIPAA (Health Insurance Portability and Accountability Act). The perception layer transforms raw data and legal text into semantically enriched, structured knowledge through two AI-powered pipelines.

4.2 Reasoning Layer

The reasoning layer supports two AI agents that collaborate to analyze user requests. A request interpreter parses each query into $\langle \text{user profile, intent, data type, and access purpose} \rangle$. A data mapper then accesses the *Domain-Specific Cluster* document to identify the relevant cluster and uses a *Metadata Repository* to fetch the owner information.

Know-Your-User (KYU) Agent: The KYU agent quantifies user trustworthiness using a machine learning model trained to generate a *KYU Score* (trust score). Specifically, a random forest classifier

Data Principal	Domain	Rules and Explanation	Receiving Entity
Adult Individual	Healthcare	Only with explicit consent. Can be shared with doctors or insurers under Sec 7(f–g) for emergencies or treatment.	Doctors, Insurers
Child (<18 years)	Healthcare	Only shared in medical emergencies or by guardian’s consent. No marketing-based sharing.	Guardian, Emergency Services
Person with Disability (via guardian)	Government Services	Government may process or share data for benefits via the guardian authority.	Guardian, Government
Hindu Undivided Family (HUF)	Finance & Banking	Shared with tax authorities, legal entities under applicable tax and property laws.	Tax Authorities, Legal Entities
Company/Firm	Employment & HR Tech	Employee data can be shared internally for compliance, payroll, and disciplinary action. Not externally without consent/legal order.	Internal Company Departments
Association or Body of Individuals	Startups and IT Services	Membership data can be shared internally; external sharing must follow Sec 6 consent norms.	Internal Teams
State	Government Services	May share across departments or contractors under legal authority without user consent.	Government Departments, Contractors
Artificial Juristic Person (e.g., Trust, NGO)	Startups and IT Services	Can only share personal data of beneficiaries with explicit consent or under governing law.	Legal Authorities, Government Schemes

Table 1: Selective tuples from Compliance Repository built over DPDP

is employed, trained on a synthesized dataset using k -fold cross-validation, achieving an accuracy of 98%. The model evaluates the user’s identity and context (as parsed by the request interpreter) to produce a *KYU Score* (trust score) categorized as low, moderate, or high. This score directly informs whether the data can be safely and ethically shared with the user.

The model is trained using two key inputs: the requester’s email address and the stated purpose of the request. Email addresses are classified into two trust categories: **personal** (low trust) and **organizational** (high trust). Similarly, purposes are categorized into three levels: **organizational use** (high trust), **self-use** (moderate trust), and **external use** (low trust). For example, consider the request for data access with the following attributes:

- **Email:** person_1@iiitb.ac.in
- **Purpose:** Self Use
- **Requested Attributes:** studentID, Age_Years, SchoolType
- **Source File:** Education_Child_Education.csv

In this case, the email domain is organizational (iiitb.ac.in), which is assigned a high trust score, while the stated purpose is self-use, which is assigned a moderate trust score. By combining these factors through the KYU Trust Scoring framework, the overall trust score for the request is determined to be **moderate**, guiding subsequent data access and anonymization strategies.

Compliance Agent: The compliance agent interfaces with the compliance repository to determine the sensitivity of the data being requested. Given the domain and ownership information from the data mapper, the agent identifies matching tuples within the repository. Each tuple’s sensitivity level is computed using a hybrid approach involving large language models (LLMs), specifically LLaMA [7] with retrieval-augmented generation (RAG) [6]. Sensitivity outputs are validated using a human-in-the-loop (HITL)

process involving domain experts. The final output is a data sensitivity classification (low, moderate, or high), which contributes to the formation of the data profile used in subsequent policy enforcement.

Exceptions in Sensitivity Determination: If the specific combination of attributes, domain, and ownership provided in a request is not found in any tuple within the compliance repository, the data is by default classified as **low sensitivity**. This approach aligns with DPDP provisions, where unlisted combinations are not explicitly recognized as protected under the law. Consequently, such data does not trigger heightened safeguards, allowing the compliance agent to apply minimal enforcement measures.

4.3 Orchestration Layer

The orchestration layer serves as the policy alignment engine. It synthesizes user trust profiles and data sensitivity classifications to generate context-appropriate privacy strategies. Example of strategies are consent management, anonymization, encryption, so on. The current implementation employs a rule-based mapping mechanism, wherein the choice of anonymization strategy is governed by the interplay between the *KYU Score* (trust score) and the sensitivity level of the data. For instance, when the *KYU Score* (trust score) is high and data sensitivity is low, the data may be shared in its raw form. Conversely, in scenarios where the *KYU Score* (trust score) is low and data sensitivity is high, stricter anonymization techniques such as masking or encryption are applied to ensure privacy preservation. The output is a concrete privacy action plan referred to as *Strategy*, forwarded to the action layer.

4.4 Action Layer

Finally, the action layer operationalizes the *Strategy*. A retrieval engine constructs an SQL query to access the data. The compliance

engine then applies the designated privacy-preserving transformation, such as generalization, masking, or encryption, mentioned in the *Strategy*. The policy-compliant output is delivered to the user.

Overall, this architecture represents a software-engineered solution for embedding AI into legally regulated data systems. It advances the design of agentic AI systems that are modular, interpretable, and aligned with data protection laws. By decomposing compliance into discrete, cooperating software agents, the system supports scalable, traceable, and ethically robust data access for engineering responsible AI in real-world applications.

5 Evaluation Metric: Anonymisation Score

To quantitatively assess the degree of privacy preservation under the DPDP Act, we define the *Anonymisation Score* as a normalized measure of transformation applied to sensitive data through masking, generalization, or pseudonymization. Given a dataset with N records and M attributes, let O_{ij} and A_{ij} denote the original and anonymized values, respectively, for the j -th attribute in the i -th record. The Anonymisation Score is defined as:

$$\text{Anonymisation Score} = \frac{1}{N \cdot M} \sum_{i=1}^N \sum_{j=1}^M D(O_{ij}, A_{ij})$$

where $D(O_{ij}, A_{ij})$ is a domain-appropriate context-aware distance metric that quantifies the level of transformation between the original and anonymized values. The score ranges from 0 (no anonymisation) to 1 (complete anonymisation), providing a consistent, interpretable basis for evaluating privacy-preserving effectiveness across heterogeneous datasets and domains.

The score 0.0 indicates ‘No Anonymisation’, applied when data sensitivity is low and user trust (KYU score) is high; 0.0 – 1.0 indicates Partial Anonymisation, balances utility and privacy via selective masking or generalization; 1.0 indicates Full Anonymisation, invoked under high sensitivity or low KYU trust scenarios. Table 2 demonstrates the mean anonymization score captured across the domains. It is observed that domains such as E-commerce, Social Media, Telecom, and Healthcare exhibit higher mean Anonymisation Scores (≥ 0.62), indicating more aggressive privacy enforcement. Sectors like Government, Employment, and Travel, capturing aggregated values, demonstrate lower scores (≤ 0.40), suggesting relatively lenient anonymisation.

Domain	Score	Domain	Score
E-commerce	0.63	Healthcare	0.62
Social Media	0.63	Education	0.54
Telecom	0.63	Finance	0.49
Startups	0.44	Travel	0.40
Employment	0.37	Government	0.35

Table 2: Mean Anonymisation Score obtained across domains in experiments

6 Implementation

To operationalize privacy-aware decision-making and legal compliance, we employ *CrewAI*, a modular framework for coordinating cooperative intelligent agents in goal-driven workflows. *CrewAI*

enables structured yet flexible orchestration of agents such as the *Compliance Agent*, *KYU Agent*, and *Compliance Orchestrator*. Each agent is defined as a mission-driven component responsible for distinct stages in the data governance pipeline, including meta-data resolution, sensitivity scoring, contextual trust estimation, and enforcement via privacy-preserving strategies.

The framework allows agents to operate both independently and collaboratively, supporting rapid prototyping, fault isolation, and rigorous evaluation. This makes *CrewAI* ideal for embedding legal reasoning, policy enforcement, and adaptive anonymisation strategies into real-world data systems. It ensures the architecture remains compliant, explainable, and testable under diverse domains.

Case Study: Finance Domain

To evaluate the end-to-end system, we ingested 36 datasets spanning multiple sectors.

A sample user request from the Finance and Banking domain is as follows:

User Request:

Email: person_1@gmail.com

Purpose: Organisational Use

Requested Attributes: annual_income, loan_status, monthly_expenditure

Source File: Finance_Banking_Adult_FinanceBanking.csv

The requested source file is processed by the Data Mapper, which uses *Domain-Specific Clustering* document to classify the domain as ‘Finance & Banking’ and identify the data owner as ‘Adult Individual’ from the *Metadata Repository*. The *KYU Agent* assigns a ‘Moderate’ trust level to the requester after calculating a dynamic trust score based on contextual inputs such as organizational use and a personal email id like person_1@gmail.com. After receiving this metadata, the *Compliance Agent* evaluates the monthly_expenditure, loan_status, and annual_income data attributes and assigns a sensitivity level as ‘High’ on the basis of relevant tuples from *Compliance Repository*. *Compliance Orchestrator* uses the trust score and sensitivity level to identify *partial masking anonymization* technique as a strategy for this request. Figure 2 depicts the output for the user request. With a *moderate KYU Score* (trust score) and *high* data sensitivity, the system applied *partial masking*, resulting in an *Anonymisation Score* of 0.4837. It also includes legal explanations based on the DPDP Act and keeps clear logs of what changes were made to the data. This helps ensure the system is easy to understand, follows the rules, and adapts based on **who** is asking for the data, **why** data is being requested (purpose), and **which** dataset, attributes are requested (owner, domain) — all important parts of building trustworthy and responsible software.

7 Operationalizing Data Governance

The proposed approach is aligned with responsible AI principles, emphasizing the flexibility and extensibility of the proposed agentic framework to support key responsible AI features.

Explainability and Legal Justifiability are demonstrated through field-level, human-readable justifications rooted in legal norms like the DPDP Act. For each sensitive attribute (e.g., annual_income), the system outlines its sensitivity, legal basis for sharing, and eligible receiving entities (e.g., RBI, credit bureaus). The dynamic

Request Processed	Applied Anonymization Strategies:
Domain (Selected): Finance & Banking	• partial_masking
Purpose: Organisational Use	
Data Source: Finance_Banking_Adult_FinanceBanking.csv	Anonymization Results (unique values processed):
Attributes: annual_income, loan_status, monthly_expenditure	• annual_income: 2170516.25 → *****16.25
About (Metadata): Adult Individual	• annual_income: 1023041.77 → *****41.77
Domain (Metadata): Finance & Banking	• annual_income: 366984.18 → *****84.18
KYU Trust Score: Moderate	• annual_income: 283606.08 → *****06.08
Overall Sensitivity for Java: High	• annual_income: 1591822.16 → *****22.16
Data Filtering Score (Alpha - from Java): 0.4837	• annual_income: 381163.58 → *****63.58
	• annual_income: 2011124.19 → *****24.19
	• annual_income: 316829.48 → *****29.48
	• annual_income: 2357258.87 → *****58.87
	• annual_income: 1426096.14 → *****96.14
	• annual_income: 1591712.15 → *****12.15
DPDP Compliance and Explanation	
annual_income:	
Domain: Finance & Banking, Sensitivity: High, Explanation: Can be shared with credit bureaus or RBI under legal obligation. Consent required otherwise. Can be shared with credit bureaus, collection agencies if permitted under law., Receiving Entity: Credit Bureaus, RBI, Collection Agencies	
loan_status:	
Domain: Finance & Banking, Sensitivity: High, Explanation: Can be shared with credit bureaus or RBI under legal obligation. Consent required otherwise. Can be shared with credit bureaus, collection agencies if permitted under law., Receiving Entity: Credit Bureaus, RBI, Collection Agencies	
monthly_expenditure:	
Domain: Finance & Banking, Sensitivity: High, Explanation: Can be shared with credit bureaus or RBI under legal obligation. Consent required otherwise. Can be shared with credit bureaus, collection agencies if permitted under law., Receiving Entity: Credit Bureaus, RBI, Collection Agencies	

Figure 2: Context-Aware Anonymization and Compliance Justification for Finance & Banking Data

KYU Score (trust score) and attribute-level sensitivity scores make anonymization decisions interpretable and auditable in natural language.

Quantitative Anonymisation Score bridges AI model behavior and measurable Software Engineering quality. By applying a domain-aware distance metric to quantify transformation, the system produces a normalized score (0–1) for privacy impact. This formal, interpretable metric supports comparison, traceability, and integration into quality assurance pipelines.

Modular Agent-Oriented Design using CrewAI allows composable agents like the *Compliance Agent* and *KYU Agent* to manage distinct responsibilities. This modular design supports scalability, maintainability, and testability for orchestrating complex governance workflows.

Traceability and Auditing are built-in, with field-level anonymization logs (e.g., 2170516.25 → *****16.25) paired with compliance explanations. Such granular output enables full traceability and auditability, essential for regulated domains.

Domain Adaptability and Compliance Mapping allows the system to auto-detect data domains (e.g., Finance) and apply domain-specific compliance rules. This ensures cross-domain scalability and consistent, context-aware enforcement across varied datasets. From a **software development** standpoint, the framework operationalizes compliance as a first-class software artifact. It formalizes ethical and legal reasoning into programmable entities, enabling machine-interpretable justifications, traceable decision flows, and fine-grained policy enforcement. The system doesn’t merely annotate AI decisions post hoc; it governs them at runtime through explainable, testable, and auditable workflows. Such automated

enforcement pipelines move beyond conventional MLOps to instantiate compliance-aware DevOps for AI systems.

8 Summary and Future Work

This work presents an automated, agentic software framework for privacy-preserving data governance, with a focus on dynamic compliance under the DPDP Act. By combining contextually enriched processing pipelines, ML-based trust evaluation (*KYU Score*), and modular agents orchestrated via CrewAI, the system achieves context-aware privacy enforcement. The proposed layered approach of the framework supports maintaining core software engineering principles such as modularity, explainability, and traceability. While the current implementation is centered around the DPDP Act, the proposed framework is designed to be adaptable to other regulations and legal frameworks. Future work will focus on integrating multiple regulatory requirements into a unified system that can intelligently identify the most relevant context and resolve any conflicts among them. Additionally, the framework can be extended to support cross-border governance and compliance scenarios. From a technical standpoint, future work involves incorporating Retrieval-Augmented Generation (RAG) to enhance contextual understanding and interpretation of legal texts. These enhancements aim to push the boundary of compliance-by-design and ethics-as-code, positioning the framework as a foundational step toward fully automated, ethically aligned software systems.

Acknowledgments

The research activities described in the paper were supported by (a) Center for Internet of Ethical Things established by the Karnataka Innovation & Technology Society, Dept. of IT, BT and S&T, Government of Karnataka, India and (b) Center for Technology Research and Innovation (Digital Governance) established by the Center for E-Governance, Government of Karnataka, India.

References

- [1] 2024. ARX Data Anonymization Tool. Available: <https://arx.deidentifier.org/>. Accessed: 2024-09-30.
- [2] Sultan Alneyadi, Elankayer Sithirasanen, and Vallipuram Muthukkumarasamy. 2016. A survey on data leakage prevention systems. *Journal of Network and Computer Applications* 62 (2016), 137–152.
- [3] Balbir Barn, Ravinder Barn, and Franco Raimondi. 2015. On the role of value sensitive concerns in software engineering practice. In *2015 IEEE/ACM 37th IEEE International Conference on Software Engineering*, Vol. 2. IEEE, 497–500.
- [4] Volker Boehme-Neßler. 2016. Privacy: a matter of democracy. Why democracy needs privacy and data protection. *International Data Privacy Law* 6, 3 (07 2016), 222–229. arXiv: <https://academic.oup.com/idpl/article-pdf/6/3/222/7353394/ipw007.pdf> doi:10.1093/idpl/ipw007
- [5] Ann Cavoukian et al. 2009. Privacy by design: The 7 foundational principles. *Information and privacy commissioner of Ontario, Canada* 5 (2009), 12.
- [6] Stefan Fuchs, Michael Witbrock, Johannes Dimyadi, and Robert Amor. 2024. Using Large Language Models for the Interpretation of Building Regulations. arXiv:2407.21060 [cs.CL] <https://arxiv.org/abs/2407.21060>
- [7] Sudipto Ghosh, Devanshu Verma, Balaji Ganesan, Purnima Bindal, Vikas Kumar, and Vasudha Bhatnagar. 2024. InLegalLaMA: Indian Legal Knowledge Enhanced Large Language Model. In *International Joint Conference on Artificial Intelligence*.
- [8] Google. 2024. *Privacy Sandbox*. Accessed: 2024-10-25.
- [9] Waqar Hussain, Davoud Mougouei, and Jon Whittle. 2018. Integrating social values into software design patterns. In *Proceedings of the international workshop on software fairness*. 8–14.
- [10] Jun Iio, Atsushi Hasegawa, Shigeyoshi Iizuka, Seiji Hayakawa, and Hiroshi Tsujioka. 2021. Ethics in human-centered design. In *International Conference on Human-Computer Interaction*. Springer, 161–170.

- [11] Sai T Makani and Shiva D Jangampeta. 2022. Devops security tools evaluating effectiveness in detecting and fixing security holes. *DevOps-An Open Access Journal* 1, 1 (2022), 18–21.
- [12] Fauzan Prasetyo Eka Putra, Ubaidi Ubaidi, Amir Hamzah, Walid Agel Pramadi, and Alief Nuraini. 2024. Systematic Literature Review: Security Gap Detection On Websites Using Owasp Zap. *Brilliance: Research of Artificial Intelligence* 4, 1 (2024), 348–355.
- [13] Rodrigo Hernández Ramírez. 2020. The Meaning of ‘Good Design’ in the Age of Smart Automation: Why Human-Centered Design Needs Ethics. *Journal of Science and Technology of the Arts* 12, 3 (2020), 100–114.
- [14] Jasmin A Riebel. 2023. User-centered Design Methods in Data-Intensive Software Development Processes: A State-of-the-Art Review. (2023).
- [15] Nayan B Ruparelia. 2010. Software development lifecycle models. *ACM SIGSOFT Software Engineering Notes* 35, 3 (2010), 8–13.
- [16] Pierangela Samarati and Sabrina Capitani De Vimercati. 2000. Access control: Policies, models, and mechanisms. In *International school on foundations of security analysis and design*. Springer, 137–196.
- [17] Mojtaba Shahin, Waqar Hussain, Arif Nurwidyantoro, Harsha Perera, Rifat Shams, John Grundy, and Jon Whittle. 2022. Operationalizing human values in software engineering: A survey. *IEEE Access* 10 (2022), 75269–75295.
- [18] David Wright. 2012. The state of the art in privacy impact assessment. *Computer law & security review* 28, 1 (2012), 54–61.